

Contents

1	FR15 セキュリティ	1
1.1	0. 文書情報	1
1.2	1. 機能概要	1
1.3	2. 収録 FR-NNN 一覧	1
1.4	3. 補足説明・統合参照	1
1.5	4. 関連設計	2
1.6	5. 未確定事項・確認事項	2

1 FR15 セキュリティ

1.1 0. 文書情報

項目	内容
文書種別	機能要件 (機能グループ別)
対象システム	運営者システム (顧客管理システム)
版	v1.0
機能グループ	セキュリティ
ソース章	§ 8.16 セキュリティ
派生元 BR	BR-017, BR-028

1.2 1. 機能概要

通信暗号化 (HTTPS)、機密項目の暗号化・安全なハッシュ、レート制限、許可ドメイン検証、再入室トークン、監査ログ、最小権限、Bot 対策、不審リクエスト検知を扱う。本書はメインシステム要件と整合する参照側だが、運営者側で正本管理する PII 誤検出ルール管理 FR-064(b)(c)(d) と連携する。

1.3 2. 収録 FR-NNN 一覧

ID	要件	優先度
FR-170	通信は暗号化されること (HTTPS)	P0
FR-171	保存データのうち機密度の高い項目 (パスワード、トークン、課金情報等) は暗号化または安全なハッシュで保存されること	P0
FR-172	API・ウィジェットに対してレート制限ができること	P0
FR-173	ウィジェットの埋め込み元ドメインを検証できること (許可ドメイン以外からの読み込み拒否)	P0
FR-174	個別チャットへの再入室はメール経由のトークンや有効期限付きリンクで行えること	P0
FR-175	管理者の操作ログを監査用に保持できること	P0
FR-176	アクセス制御は最小権限の原則に従うこと (オーナー境界によるデータ分離、ユーザー種別別認可)	P0
FR-177	Bot 対策 (CAPTCHA 等) を必要に応じて実施できること	P1
FR-178	不審なリクエスト (大量アクセス、未許可ドメイン等) を検知・記録できること	P0

1.4 3. 補足説明・統合参照

- パスワードハッシュは NFR-304(メモリハードなアルゴリズム、運営者はより強パラメータ) を正本とする。
- トークン保管は NFR-305(オーナー派生 で 付きハッシュ) を正本とする。 階層は NFR-320。
- 監査ログの改ざん検知は NFR-306(ハッシュチェーン監査ログ、運営者側を正本)。日次バッチで全件検証 (NFR-602c)。

- 運営者は IP 許可リストの適用が可能 (NFR-311、運営者を正本)。
- 不正利用検知 (R-005) はメインシステム FR-195 が正本 (本書 § 8.1.1 のとおり)。本書は連携 IF #9(不正利用検知通知) で受信側として可視化する (本書 § 11.2)。
- 脆弱性対応 SLA(NFR-330)・SCA(NFR-331)・ペネトレーションテスト (NFR-332) はメインシステムと共通要件として両書整合。

1.5 4. 関連設計

- [../02_基本設計/index.md](#) 基本設計書 index
- [../02_基本設計/01_画面設計.md](#) § SCR-093(契約別レート制限)/ SCR-099(Webhook ペイロード差分検出)/ SCR-098(PII 誤検出報告管理)
- [../02_基本設計/02_API設計.md](#) レート制限・Webhook 検証・許可ドメイン検証
- [../02_基本設計/03_テーブル設計.md](#) `audit_logs`(ハッシュチェーン)・`rate_limit_overrides` テーブル
- [../02_基本設計/08_認証・認可設計.md](#) 6 段認可判定・最小権限
- [../02_基本設計/09_セキュリティ設計.md](#) ハッシュチェーン監査・3 区分保持・GDPR・管理
- [../02_基本設計/07_トレーサビリティマトリクス.md](#)
- [../03_詳細設計/index.md](#) 詳細設計書 index

1.6 5. 未確定事項・確認事項

- Bot 対策 (CAPTCHA) の具体採用基準・適用画面は基本設計で確定する。
- 不審リクエスト検知のしきい値は基本設計 § 11.7 を正本とする。